維護工作流程手冊｜節錄版

IT 帳號與權限管理系統 維護流程

AD・Synology NAS・郵件平台・Ragic 關聯資料維護

陳家榮｜IT維運與系統管理 ・ 版本 1.2 ・ 2026-10-29

PowerShell | SSH / Synology DSM | ISO 27001 A.5.37 書面化作業程序

節錄說明 本文件由完整版維護手冊重新編排，供面試展示系統治理、資料匯入與查核方法。組織名稱、帳號、設備、網域、路徑與內部編號均已泛化；尖括號 < > 內為範例參數。

00 設計目的

把分散於 AD、NAS 與郵件平台的帳號及權限，轉為可追溯的集中清冊。

以穩定識別鍵建立人員、帳號、群組與資料夾權限的關聯。

建立可重複執行、可驗證、可交接並可保留稽核證據的維護流程。

安全邊界 Ragic 僅保存管理屬性與關聯，不保存密碼、私鑰、權杖、雜湊或可還原憑證。

01 系統範圍與核心原則

管理對象	權威來源	Ragic 的角色
人員與任職狀態	人資／主管通知	人員主檔與生命週期追蹤
AD 帳號與群組	Active Directory	集中清冊、責任人與群組關聯
NAS 帳號、群組與 ACL	Synology NAS	跨設備盤點與權限規則追溯
郵件帳號	郵件管理平台	信箱狀態、用途及人員／責任人配對

七步標準流程

1. 備份 Ragic 現況，記錄執行時間、範圍與基準筆數。
2. 使用唯讀查詢從來源平台匯出，保留原始檔。
3. 複製工作檔並標準化欄位、日期、狀態與編碼。
4. 以 SID、系統編號＋登入帳號或 ACC|GRP 建立穩定識別鍵。
5. 依主檔優先順序匯入 Ragic，避免關聯目標尚未建立。
6. 執行連結載入與公式套用，刷新參照子表。

7 核對筆數、抽查完整鏈路，保存摘要與異常清單。

> **判斷原則** 實際平台是權限真相來源；Ragic 是某一時間點的管理快照。不可只在 Ragic 停權，就認定來源平台已完成停用。

建議維護週期

時機	範圍	主要輸出
人員異動即時	新增、調職、離職與特權變更	申請、處理與驗證紀錄
每月	AD 帳號、群組與直接成員	CSV、差異與異常清單
每季	NAS 帳號、群組、成員及根層 ACL	TXT／CSV、抽查紀錄
每半年	特權、共用、外部及未使用帳號	覆核報表與責任人確認

02 表單架構與關聯鍵

表單	識別碼	一筆資料代表
人員帳號總覽	USR-xxxxx	一位員工／受管理人員
資訊系統主檔	SYS-xxxxx	一項 AD、NAS 或郵件服務
系統帳號清冊	ACC-xxxxx	某系統中的一個登入身分
帳號群組清冊	GRP-xxxxx	某系統中的一個群組
帳號群組成員關聯表	MEM-xxxxx	一個帳號加入一個群組
NAS 資料夾主檔	FOLDER-xxxxx	一個共享資料夾或受管路徑
NAS 權限清冊	PERM-xxxxx	一條資料夾授權規則

資料	穩定鍵	理由
AD 帳號	AD|<帳號 SID>	改名後 SID 通常仍可維持識別
NAS 帳號	<SYS>|<Login>	避免不同 NAS 同名帳號誤配
群組	<SYS>|<SID 或 GID>	群組名稱變更時仍可追蹤
成員關聯	<ACC>|<GRP>	一個帳號加入一個群組形成唯一關係

> **關聯方向** 連結欄位由關聯資料指向主檔，用以保存穩定鍵；主檔再透過反向參照子表呈現「持有帳號」或「所屬群組」。畫面可雙向查閱，不等於資料庫必須建立兩組互相寫入的欄位。

最低必要狀態欄位

來源狀態
來源平台實際啟用／停用狀態。

管理狀態
有效、待確認、已移除或例外。

同步日期
本筆資料最後一次被來源匯出覆核的日期。

責任人
共用、服務或外部帳號必須指定負責人。

03 AD 帳號匯出（PowerShell）

> **使用方式** 在已安裝 RSAT ActiveDirectory 模組的受管電腦執行。尖括號內是範例參數，使用前必須替換；查詢帳號只需具備必要的唯讀權限。

3.1 參數與前置檢查

```powershell
Import-Module ActiveDirectory
$Stamp     = Get-Date -Format "yyyyMMdd_HHmmss"
$ExportDir = "<受控輸出根目錄>\AD_$Stamp"
$SystemId  = "<AD 系統編號>"
New-Item -ItemType Directory -Path $ExportDir -Force | Out-Null

Get-Module ActiveDirectory | Select-Object Name, Version
Test-Path $ExportDir
```

3.2 帳號清冊（節錄欄位）

```powershell
Get-ADUser -Filter * -Properties DisplayName, Mail, Enabled,
    EmployeeID, Department, SID, LastLogonDate |
  ForEach-Object {
    [pscustomobject]@{
      '所屬資訊系統' = $SystemId
      '登入帳號'     = $_.SamAccountName
      '帳號狀態'     = if ($_.Enabled) { '啟用' } else { '已停用' }
      '員工編號'     = $_.EmployeeID
      '持有人姓名'   = $_.DisplayName
      '公司信箱'     = $_.Mail
      '帳號SID'      = $_.SID.Value
      '同步鍵'       = "AD|$($_.SID.Value)"
      '最近登入日期' = $_.LastLogonDate
    }
  } |
  Export-Csv -Path "$ExportDir\AD_Accounts.csv" -NoTypeInformation -Encoding UTF8
```

注意　LastLogonDate 取自會在網域控制站間複寫的時間戳，與實際最後登入可能相差約兩週；判斷閒置帳號時以「超過門檻天數」看待，不作精確日期使用。

3.3 單筆新人／異動帳號

```powershell
$Login = "<本次登入帳號>"   # 每次改成實際帳號
Get-ADUser -Identity $Login -Properties DisplayName, Mail, Enabled,
    EmployeeID, Department, SID |
  Select-Object SamAccountName, DisplayName, Mail, Enabled,
    EmployeeID, Department, SID
```

> **重要**　`$Login` 必須改成這次新增或異動的 AD 登入帳號；<AD 系統編號> 則沿用 Ragic 資訊系統主檔既有編號，除非主檔本身已重建。

04 AD 群組與成員匯出

4.1 群組主檔

```powershell
Get-ADGroup -Filter * -Properties GroupCategory, GroupScope, SID |
  ForEach-Object {
    [pscustomobject]@{
      '所屬資訊系統' = $SystemId
      '群組名稱'     = $_.Name
      '群組類型'     = $_.GroupCategory
      '群組範圍'     = $_.GroupScope
      '群組SID'      = $_.SID.Value
      '同步鍵'       = "$SystemId|$($_.SID.Value)"
    }
  } |
  Export-Csv -Path "$ExportDir\AD_Groups.csv" -NoTypeInformation -Encoding UTF8
```

4.2 直接成員關聯

```powershell
$Rows = foreach ($Group in Get-ADGroup -Filter *) {
  Get-ADGroupMember -Identity $Group -ErrorAction SilentlyContinue |
    Where-Object objectClass -eq 'user' |
    ForEach-Object {
      $User = Get-ADUser -Identity $_ -Properties SID
      [pscustomobject]@{
        '帳號同步鍵' = "AD|$($User.SID.Value)"
        '群組同步鍵' = "$SystemId|$($Group.SID.Value)"
        '成員關聯鍵' = "AD|$($User.SID.Value)|$($Group.SID.Value)"
        '資料來源'   = 'Active Directory 匯出'
      }
    }
}
$Rows | Export-Csv -Path "$ExportDir\AD_GroupMembers.csv" -NoTypeInformation -Encoding UTF8
```

4.3 匯出後驗證

```powershell
$A = Import-Csv "$ExportDir\AD_Accounts.csv"
$G = Import-Csv "$ExportDir\AD_Groups.csv"
$M = Import-Csv "$ExportDir\AD_GroupMembers.csv"
"Accounts=$($A.Count); Groups=$($G.Count); Members=$($M.Count)"

# 有輸出代表鍵值重複，需先排除再匯入
$A | Group-Object -Property '同步鍵'     | Where-Object Count -gt 1
$G | Group-Object -Property '同步鍵'     | Where-Object Count -gt 1
$M | Group-Object -Property '成員關聯鍵' | Where-Object Count -gt 1
```

> **範圍說明**　此範例匯出直接群組成員。若稽核需求包含巢狀群組的有效權限，應另行計算遞迴成員，並在欄位中明確區分「直接」與「繼承」。成員數很多的群組，`Get-ADGroupMember` 可能受伺服器筆數上限影響，可改讀群組的 `Members` 屬性。

05 Synology NAS 匯出（SSH）

使用方式 以核准的管理方式登入 NAS，將輸出寫入受控匯出路徑；不在指令、批次檔或文件中保存密碼。不同 DSM 版本與權限模式可能需調整 synoacltool 路徑或參數。

5.1 設定本次參數

```shell
NAS_NAME="<NAS 主機名稱>"
EXPORT_DIR="<受控輸出路徑>"
STAMP="$(date +%Y%m%d_%H%M%S)"
OUT="$EXPORT_DIR/${STAMP}_${NAS_NAME}"
mkdir -p "$OUT"
hostname
date
```

5.2 匯出本機帳號、群組與群組成員

```shell
getent passwd > "$OUT/accounts.txt"
getent group  > "$OUT/groups.txt"

getent group | awk -F: -v nas="$NAS_NAME" '
BEGIN { OFS = "\t"; print "NAS", "Group", "Member" }
{
  n = split($4, a, ",")
  for (i = 1; i <= n; i++) if (a[i] != "") print nas, $1, a[i]
}' > "$OUT/group_members.tsv"
```

5.3 匯出共享資料夾根層 ACL

```shell
for SHARE in /volume*/*; do
  [ -d "$SHARE" ] || continue
  case "$(basename "$SHARE")" in
    @*|\#*) continue ;;   # 排除 @appstore、#recycle 等系統目錄
  esac
  echo "### SHARE=$SHARE"
  synoacltool -get "$SHARE" 2>&1
done > "$OUT/root_acl.txt"
```

5.4 驗證

```shell
wc -l "$OUT/accounts.txt" "$OUT/groups.txt" \
      "$OUT/group_members.tsv" "$OUT/root_acl.txt"
head -n 5 "$OUT/group_members.tsv"
grep -c '^### SHARE=' "$OUT/root_acl.txt"
```

解析原則 NAS 同名帳號不可只用 Login 配對，應加入所屬資訊系統編號。ACL 的 allow／deny、讀寫／唯讀及群組／使用者類型必須分欄，不能只保留一段文字。

5.5 首次盤點後的實務補充

情況	處理方式
需要帳號啟用狀態	以 `synouser --get` 逐一讀取；此指令需 root 權限，腳本開頭先檢查，未取得權限即停止，避免產生整份「Permission denied」的無效檔案
NAS 未開放 SSH	改由 DSM 管理介面匯出使用者清單，比對帳號狀態與群組；資料夾 ACL 另以權限畫面佐證
套件服務帳號	家目錄位於套件路徑的帳號屬系統服務，保留於來源檔但不納入人員帳號盤點
腳本部署	腳本只讀取資料；無法以檔案總管放置時，可在 SSH 以 here-document 直接建立

06 Ragic 匯入與關聯更新

6.1 匯入前檢查

檢查點	合格條件
原始檔	已唯讀保存，工作檔另存；編碼可正確顯示中文
識別鍵	無空白、無非預期重複，系統編號已存在
連結目標	USR、SYS、ACC、GRP 等主檔已先建立
狀態值	符合 Ragic 選項，例如啟用／已停用、有效／已移除
備份	已匯出匯入前清冊並記錄基準筆數

6.2 建議匯入順序

順序	表單與動作
1	資訊系統主檔（SYS）：人工建立並維持固定編號
2	人員帳號總覽（USR）：先確認在職人員與員工編號
3	系統帳號清冊（ACC）：以同步鍵更新；新增帳號再配對人員
4	帳號群組清冊（GRP）：以系統＋SID／GID 更新
5	成員關聯表（MEM）：待 ACC 與 GRP 均存在後匯入
6	NAS 資料夾（FOLDER）與權限（PERM）：最後匯入 ACL

6.3 匯入模式與後續動作

情境	匯入策略	完成後
初次建立	產生新資料	核對新增筆數與連結成功率
定期同步	更新舊資料；找不到鍵時才新增	執行連結載入、公式套用與參照刷新
只處理離職／停用	以穩定鍵更新狀態，不刪歷史	確認來源平台已停用並保留日期

6.4 首次盤點後補充的匯入規則

規則	原因
CSV 第一欄必須是每筆唯一的鍵（帳號用同步鍵、成員用 ACC ｜ GRP）	平台以第一欄比對；若第一欄每筆相同，所有資料會被當成同一筆而互相覆蓋
新增與更新分成不同匯入檔：帳號新增、帳號狀態、成員新增、成員移除	有對應的空白欄位會清空既有資料，例如人員連結
匯入時執行連結與載入；只修正文字欄位時例外	未執行時載入欄位為空白；修正文字時執行載入反而會被帶回舊值
修正連錯的人員，從帳號端處理，並直接匯入要改的值	人員頁子表為自動彙總無法直接改；連結值未變時重新匯入不會觸發載入
匯入前檢查同步鍵是否重複，先處理再匯入	重複鍵會讓更新落到其中任一筆，結果無法預期

差異比對　平台匯出檔與清冊匯出檔放入本機執行的比對工具，自動產生差異清單與上述四種匯入檔；修正與匯入後重跑，差異歸零即作為完成證據。

為何要套用公式　CSV 匯入會寫入欄位，但不一定立即重算既有資料的公式或反向參照。MEM 的「系統一致性」及人員頁面的群組子表，應在匯入後執行公式套用／連結更新，再進行驗證。

07　驗證、例外處理與稽核證據

7.1 最小驗證清單

層級	抽查內容	通過標準
筆數	匯出、整理、匯入前後筆數	差異可說明且有異常清單
帳號	來源狀態、登入帳號、系統及持有人	與來源平台一致
群組	ACC → MEM → GRP → SYS	鏈路完整且系統一致
NAS 權限	PERM → FOLDER → SYS 與授權對象	權限等級及對象一致
人員頁面	持有帳號與所屬群組參照子表	新增、停用與移除均可追溯

7.2 常見異常與處理

現象	可能原因	處理
系統一致性顯示不一致	ACC 與 GRP 的系統編號不同，或公式未重算	先核對來源鍵，再套用公式到全部資料
人員頁面沒有群組子表資料	MEM 未匯入、關聯鍵未更新或參照尚未刷新	更新 MEM 關聯鍵並執行連結／參照更新
同名帳號配錯人	只用 Login／姓名比對	改用 SYS＋Login、SID 及員工編號交叉確認
離職人員仍有權限	只改 Ragic，未停用來源平台	先完成 AD／NAS／郵件停權，再匯出驗證

7.3 建議保存證據

原始匯出檔、整理後匯入檔及檔案雜湊／版本日期。

執行人、執行時間、資料範圍、指令版本與來源平台版本。

匯入模式、鍵值欄位、成功／失敗筆數與錯誤清單。

抽查樣本、覆核人、結論及待改善事項。

對應 ISO/IEC 27001:2022

A.5.37 書面化作業程序

七步流程、匯入順序與驗證清單皆已文件化，可交接執行

A.5.18 存取權限

定期匯出與差異核對，支援權限複審與離職回收

7.5 文件化資訊

保存原始檔、雜湊、執行人與抽查紀錄作為證據

僅為設計對照，不代表已通過驗證。